

Баг №1: Некоректний тип даних 0 - 9999999...

 Додати еріс /  KAN-6

Описание

Environment:

- Tool: Postman / DBeaver (SQLite)
- Endpoint: POST /store/order/0

Steps to Reproduce (Кроки відтворення):

1. Відкрити у Postman запит "Замовлення на 0 або 9999....".
2. У рядку URL вказати граничне значення ID: 0.
3. Натиснути Send.
4. Виконати SQL для перевірки ціни: `SELECT * FROM Track WHERE UnitPrice = 0;`

Expected Result (Очікуваний результат):

400 Bad Request (Invalid ID)

Actual Result (Фактичний результат):

405 Method Not Allowed. Сервер видає помилку методу замість того, щоб повідомити про некоректний ID замовлення.

Swagger API Testing Project / Automation Order Кейс 1 / **Замовлення на 0 або 9999....**

POST **{{url}} /store/order/0**

Docs Params Authorization Headers (9) Body **Scripts** Settings

Pre-request

Post-response

```
1 pm.test("Перевірка замовлення на граничні значення (0-9999999999)", function () {
2   pm.expect(pm.response.code).to.be.oneOf([400, 500]);
3 });
```

Body Cookies Headers (8) Test Results (0/1) 405 Method Not Allowed 131 ms

XML Preview Debug with AI

```
1 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
2 <apiResponse>
3   <type>unknown</type>
4 </apiResponse>
```

SELECT * FROM Track WHERE UnitPrice = 0;

Track 1 X

SELECT * FROM Track WHERE UnitPrice = 0 Введите SQL выражение чтобы отфильтровать результаты

	3 Genrelid	A-Z Composer	123 Milliseconds	123 Bytes	123 UnitPrice
Таблица					
Текст					
Запись					

Обновить Save Cancel Экспорт данных ... 200 0

Баг №2: Пошук замовлень з довгим ім'ям

 [Добавить еріс](#) / [KAN-7](#)

Описание

Environment:

- Tool: Postman / DBeaver (SQLite)
- Endpoint: GET /store/order/10333333333333333333333333

Steps to Reproduce (Кроки відтворення):

1. Відкрити у Postman запит "Пошук замовлень з довгим ім'ям".
2. У рядку URL вказати ID, що перевищує максимально допустиме значення для цілого числа: 10333333333333333333333333333333. Натиснути Send.
3. Виконати SQL для перевірки наявності записів з довгими іменами: `SELECT * FROM Track WHERE LENGTH(Name) > 30 LIMIT 10;`

Expected Result (Очікуваний результат):

400 Bad Request (Invalid ID format). Сервер має коректно відповісти, що такий ID не підтримується.

Actual Result (Фактичний результат):

404 Not Found. Сервер видає помилку java.lang.NumberFormatException. Це стається тому, що система не розрахована на таку велику кількість цифр в ID і «ламається», намагаючись обробити це число.

[illegible]

The screenshot shows the SQL Studio interface. At the top, the SQL editor contains the query: `SELECT * FROM Track WHERE LENGTH(Name) > 30 LIMIT 10;`. Below the editor, a tab labeled "Track 1" is active. The main area displays a table with the following data:

	TrackId	Name	AlbumId	MediaTypeId	GenreId	CorrelationId
1	1	For Those About To	1	1	1	Angus Y
2	65	Samba De Uma Noite	8	1	2	[NULL]
3	70	Se Todos Fossem I	8	1	2	[NULL]
4	73	Corcovado (Quiet	8	1	2	[NULL]
5	125	Spanish moss-"A s	13	1	2	Billy Co
6	156	Wheels Of Confusi	17	1	3	Tony Lo
7	165	Under The Sun/Eve	17	1	3	Tony Lo
8	201	Keep It To Myself	20	1	6	Sonny E
9	221	Atrás Da Verd-E-R	21	1	7	David C
10	223	Sozinho (Hitmaker	22	1	7	[NULL]

The interface includes a sidebar on the left with icons for "Таблица" (Table), "Текст" (Text), and "Запись" (Record). At the bottom, there is a toolbar with buttons for "Обновить" (Refresh), "Save", "Cancel", and "Экспорт данных ..." (Export data ...). The status bar at the bottom shows "EET ru", "Запись" (Record), "Инт. вставка" (Int. insert), "21:55:1410", and "Sel: 0 | 0".

Баг №3: Неінформативна помилка (*unknown/bad input*) при порушенні синтаксису JSON у POST

✎ Додати епіс / 🚩 KAN-8

Описание

Environment:

- Tool: Postman / DBeaver (SQLite)
- Endpoint: POST /store/order

Steps to Reproduce (Кроки відтворення):

1. Відкрити у Postman запит "Оновити замовлення".
2. Перейти у вкладку Body → raw → JSON.
3. Внести синтаксичну помилку в JSON-структуру (наприклад, порушити закриваючі дужки, як показано на скріншоті). Натиснути кнопку Send.
4. Виконати SQL-запит для перевірки, чи не було створено некоректного запису в базі: `SELECT * FROM Track WHERE TrackId = 101;`

Expected Result (Очікуваний результат):

400 Bad Request. Сервер має повернути зрозуміле повідомлення про помилку парсингу JSON (наприклад: "Unexpected character at line 7")

Actual Result (Фактичний результат):

400 Bad Request. Сервер повертає загальне повідомлення "message": "bad input". Тип помилки вказано як "unknown". Це не дає жодної конкретики щодо того, що саме в структурі запиту є невірним.

Баг №4: Критична помилка сервера (500 Internal Server Error) при невідповідності типів даних у полі "quantity"

✎ Додати епіс / 🚨 KAN-9

Описание

Environment:

- Tool: Postman / DBeaver (SQLite)
- Endpoint: POST /store/order.

Steps to Reproduce (Кроки відтворення):

1. Відкрити запит у Postman Створити замовлення /store/order.
2. У вкладці Body → raw → JSON змінити числове значення в полі quantity на текстове: "quantity": "UNLIMITED_TEST". Натиснути кнопку Send.
3. Виконати SQL-запит для перевірки останнього запису в базі:
`SELECT * FROM Track ORDER BY TrackId DESC LIMIT 1;`

Expected Result (Очікуваний результат):

Сервер має повернути 400 Bad Request із чітким поясненням, що поле quantity має бути числом.

Actual Result (Фактичний результат):

Сервер повертає 500 Internal Server Error. База даних не оновлюється (останній запис залишається старим, наприклад, TrackId: 3503).

Баг №5: Критичне порушення цілісності БД (дублювання ID)

Додати еррис / KAN-10

Описание

Environment:

- Tool: Postman / DBeaver (SQLite)
- Endpoint: POST /store/order

Steps to Reproduce (Кроки відтворення):

1. Відкрити у Postman запит "Створення замовлення".
2. Відправити валідний JSON-запит із конкретним ID (наприклад, "id": 102). Отримати статус 200 OK.
3. Повторно натиснути кнопку Send у Postman з тим самим тілом запиту (той самий id: 102).
4. Виконати SQL-запит у DBeaver для перевірки кількості записів:
`SELECT count(*) FROM (SELECT TrackId FROM Track WHERE TrackId = 102 UNION ALL SELECT TrackId FROM Track WHERE TrackId = 103);`

Expected Result (Очікуваний результат):

409 Conflict. Система має заборонити створення дублікату і видати помилку, що такий ID вже існує.

Actual Result (Фактичний результат):

200 OK. Сервер обидва рази повертає успішний статус. SQL-перевірка видає результат 2. Це підтверджує критичну вразливість: архітектура бази даних дозволяє дублювати замовлення з однаковими ID

Swagger API Testing Project / Automation Order Кейс 1 / Створити список замовлень

POST {{url}} /store/order

Docs Params Authorization Headers (9) Body Scripts Settings

none form-data x-www-form-urlencoded raw binary GraphQL JSON

```
1 {
2   "id": "101",
3   "category": "Electronics",
4   "name": "iPhone 15 Pro",
5   "quantity": "1",
6   "status": "in_stock"
7 }
8
9 {
10  "id": "102",
11  "category": "Electronics",
12  "name": "iPhone 16",
13  "quantity": "1",
14  "status": "in_stock"
15 }
16
17 {
18  "id": "103",
19  "category": "Electronics",
```

Body Cookies Headers (8) Test Results (1/1) 200 OK

{ } JSON Preview Visualize

```
1 {
2   "id": 101,
3   "petId": 0,
4   "quantity": 1,
5   "status": "in_stock",
6   "complete": false
7 }
```

Swagger API Testing Project / Automation Order Кейс 1 / Створення дублікату

POST `{{url}} /store/order`

Docs Params Authorization Headers (9) **Body** Scripts Settings

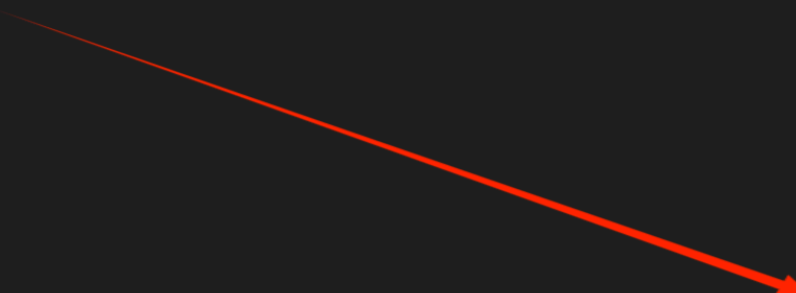
☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL **JSON**

```
1 {
2   "id": "102",
3   "category": "Electronics",
4   "name": "iPhone 16",
5   "quantity": "1",
6   "status": "in_stock"
7 }
```

Body Cookies Headers (8) Test Results (1/1) 200 OK

{ } JSON Preview Visualize

```
1 {
2   "id": 102,
3   "petId": 0,
4   "quantity": 1,
5   "status": "in_stock",
6   "complete": false
7 }
```



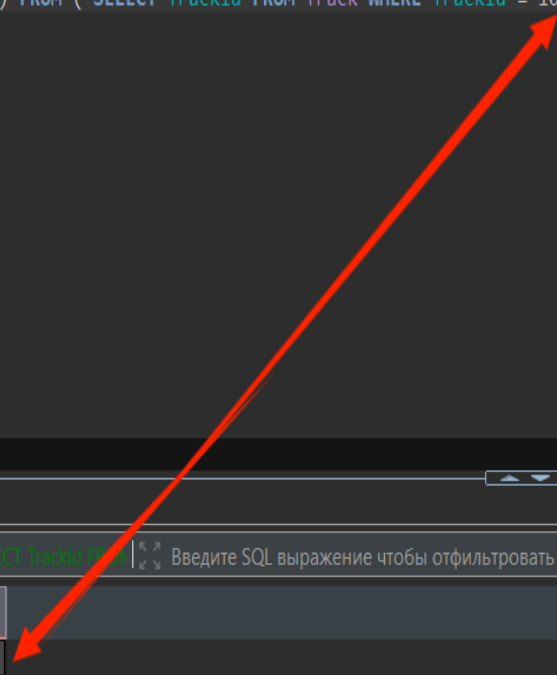
```
SELECT count(*) FROM ( SELECT TrackId FROM Track WHERE TrackId = 102 UNION ALL SELECT TrackId FROM Track WHERE TrackId = 102);
```

Результат 1 X

SELECT count(*) FROM (SELECT TrackId FROM Track WHERE TrackId = 102 UNION ALL SELECT TrackId FROM Track WHERE TrackId = 102); Введите SQL выражение чтобы отфильтровать результаты

	count(*)
1	2

Значение X



Результати тестування сайту

<https://petstore.swagger.io/v2/store/order>

<https://petstore.swagger.io/v2/user>

Manual Testing, Postman, DBeaver, SQL, Jira.

Колекція:

<https://andrey-dnepr.atlassian.net/jira/software/projects/KAN/boards/1>

https://api.postman.com/collections/51898931-b9a26de6-f0dd-4560-a6dd-485899d121bb?access_key=PMAT-01KK1BZACMY7AJFGDAXCZHY6FD

Для перегляду моєї інтерактивної дошки Jira, Postman будь ласка, надішліть запит на доступ на мій email:

ae7656cp@gmail.com